

TLP:CLEAR

ВЕС через скомпрометированный ящик НКО + AiTM-кит Tycoon 2FA

Thread hijacking, злоупотребление Microsoft Customer Voice и
многослойная AiTM-инфраструктура

BEC | Thread Hijacking | AiTM | Tycoon 2FA | Microsoft 365 | PaaS Phishing

Параметр	Значение
Дата инцидента	11 мая 2026, 21:22 UTC
Дата анализа	12 мая 2026
Классификация	TLP:CLEAR
Уровень угрозы	ВЫСОКИЙ
Тип	BEC / Thread Hijacking / AiTM Phishing / PaaS Phishing Kit
Тема письма	FW: ACH Submission Attached
Отправитель	Скомпрометированный M365-ящик (французская НКО, EU-тенант)
Получатель	Финансовый ящик (европейская компания, Google Workspace)
Ссылка-приманка	hxxps://nam[.]dcv[.]ms/o9XDteis3W (Microsoft Customer Voice)
IP финальной стадии	198[.]23[.]210[.]61 (RackNerd / ColoCrossing, США)
Семейство кита	Tycoon 2FA / Mamba 2FA (Storm-1575)

1. Краткая сводка

11 мая 2026 года фишинговое письмо высокой степени достоверности было доставлено с реального Microsoft 365-ящика французской некоммерческой организации на финансовый адрес европейской компании. Письмо прошло через подлинные серверы исходящей почты Exchange Online — это компрометация аккаунта, а не подделка адреса.

Атака использует три уровня обхода защиты. Первый: отправляющий аккаунт настоящий, письмо отправлено через легитимные серверы M365 и проходит проверки SPF/DKIM/DMARC. Второй: письмо встроено в реальную переписку из взломанного ящика на французском языке — медицинское обсуждение — для создания контекстной легитимности. Третий: единственная ссылка в письме ведёт через легитимный сервис Microsoft (Customer Voice / Forms Pro, nam.dcv.ms), который включён в белые списки большинства корпоративных шлюзов.

Конечная цель — AiTM-кит семейства Tusoon 2FA / Mamba 2FA, размещённый на VPS в США. Кит показывает поддельную страницу входа Gmail/Google, фильтрует ботов и сканеры через XOR-обфусцированный API-запрос и похищает учётные данные и сессионные куки для обхода MFA. Выявлен кластер из семи параллельных фишинговых доменов на одном IP-адресе, все сертифицированы 17 апреля 2026 года.

2. Хронология атаки

Дата/время (UTC)	Событие
2026-04-17	Выпуск сертификатов Let's Encrypt для всех 7 фишинговых доменов кластера (stiofidri.company и 6 параллельных) — за 3–4 недели до атаки.
2026-05-11 14:50:51	Создание формы Microsoft Customer Voice со скомпрометированного M365-аккаунта. Заголовок: «A SECURED FILED HAS BEEN SUCCESSFULLY SHARED WITH YOU!»
2026-05-11 14:54:26	Финализация формы; ссылка-payload: hxxps://stiofidri[.]company/u@xTBw1Q9qK4Qb0ZS9gxFUS/
2026-05-11 ≤21:22	Компрометация M365-ящика отправителя (вектор: вероятно, предшествующий AiTM-цикл).
2026-05-11 21:22:03	Отправка фишингового письма через DB9PR08MB6809.eurprd08.prod.outlook.com на финансовый ящик организации-жертвы.
2026-05-12 09:05	Автосканирование URL сервисом HybridAnalysis; snapshot Microsoft Forms сохранён через URLscan.

2026-05-12 ~13:00

Начато расследование. nam.dcv.ms/o9XDteis3W возвращает HTTP 404 — форма удалена.

3. Письмо-приманка

3.1. Заголовки и аутентификация

Письмо прошло через легитимный исходящий путь Microsoft 365 (DB9PR08MB6809.eurprd08 → GV1PR08MB8132 → AM0PR83CU005.outbound → mail-westeuropeazlp170100001, IPv6 2a01:111:f403:c201::1). Этот маршрут идентичен отправке из настоящего M365-ящика в EU-регионе. Message-ID формата DB9PR08MB6809...@eurprd08.prod.outlook.com выдаётся исключительно Exchange Online при реальной отправке.

- SPF: у домена отправителя есть корректная запись (включает spf.protection.outlook.com ~all) — результат «none» на Google MX связан с особенностью пути доставки, а не с подделкой.
- DKIM: none на Google MX — подпись DKIM не была передана на хопе Microsoft → Google; это ошибка конфигурации DNS отправителя, не спуфинг.
- DMARC: v=DMARC1; p=none — политика не применяет никаких мер, только мониторинг.

Совокупность признаков подтверждает: это компрометация аккаунта (ATO), а не подделка адреса.

3.2. Thread hijacking и социальная инженерия

Атакующий извлёк из взломанного ящика реальную переписку: обмен на французском языке между медицинскими сотрудниками организации-отправителя, датированный мартом 2026 года. Переписка вставлена дословно под фишинговым текстом — для создания контекстной легитимности и включения безвредных ключевых слов, сбивающих контентные классификаторы.

- Фишинговое тело — на английском, вложенная переписка — на французском: несоответствие языков, заметное внимательному получателю.
- Поддельная подпись приписывает владельцу скомпрометированного ящика роль «Chief Financial Officer (CFO)» — в действительности это медицинский сотрудник. Повышение роли нацелено на обоснование финансового запроса ACH.
- Финансовая приманка: «Please find attached the ACH submission related to the completed balance settlement... REVIEW CONFIRMATION AND STATEMENT» — типичный скрипт BEC / мошенничества с банковскими переводами.

4. Первая стадия: злоупотребление Microsoft Customer Voice (nam.dcv.ms)

Единственная ссылка в теле письма — «REVIEW CONFIRMATION AND STATEMENT» — ведёт через nam.dcv.ms/o9XDteis3W, легитимный URL-шортенер Microsoft для продукта Customer Voice (Forms Pro). Домен находится в белых списках практически всех корпоративных решений URL-фильтрации.

Параметр	Значение
Короткий URL	hxxps://nam[.]dcv[.]ms/o9XDteis3W
Разворачивается в	hxxps://customervoice[.]microsoft[.]com/Pages/ResponsePage.aspx?id=gKJ6Dz...
Заголовок формы	«A SECURED FILED HAS BEEN SUCCESSFULLY SHARED WITH YOU!»
Скомпрометированный арендатор M365	французская НКО, EU-регион (идентификаторы

	доступны MSRC по запросу)
Создана	2026-05-11 14:50:51 UTC
Изменена	2026-05-11 14:54:26 UTC
Статус на момент расследования	HTTP 404 — удалена Microsoft или атакующим

Текст вопроса: «Dated: Fri, May 2026». Единственный CTA — «CLICK HERE TO FULL REPORTS» → [https://stiofidri\[.\]company/u@xTBw1Q9qK4Qb0ZS9gxFUS/](https://stiofidri[.]company/u@xTBw1Q9qK4Qb0ZS9gxFUS/).

По данным URLscan, этот паттерн злоупотребления Customer Voice активен с мая 2025 года: более 100 сканирований pat.dcv.ms-ссылок на нескольких языках с темами «New PDF Document Received», «Payment Advice Note», «Electronic Funds Transfer Notification». Долгосрочная многоязычная кампания глобального охвата.

5. Вторая стадия: AiTM-кит Tycoon 2FA / Mamba 2FA

5.1. Инфраструктура

Параметр	Значение
Хост-домен	stiofidri[.]company
IP-адрес	198[.]23[.]210[.]61
ASN	AS36352 — ColoCrossing / RackNerd LLC, Чикаго, США
TLS-сертификат	Let's Encrypt R13, выдан 2026-04-17, действует до 2026-07-16
CDN	Cloudflare (CF-RAY 9fa9e25929336872-NRT)
Веб-сервер	Nginx 1.18.0 на Ubuntu
Бэкенд	Laravel (куки: XSRF-TOKEN, laravel_session, samesite=none)
NS	a.dnspod.com / b.dnspod.com / c.dnspod.com (Tencent DNSPod)

5.2. Слои защиты от анализа

- CAPTCHA-шлюз: поддельный экран «Human Check / Verify identity» в стиле Gmail с динамически генерируемым 5-символьным кодом. Блокирует автоматические сканеры.
- Фильтр облачных IP: после CAPTCHA кит обращается к api.ipapi.is. При ASN любого хостинг-провайдера (AWS, Google, Microsoft, Cloudflare, OVH, Hetzner, DigitalOcean, Linode, Akamai, Fastly, AS13335, Leaseweb, M247, LSN) — редирект на www.meituan.com. Логика XOR-обфусцирована (ключ: 3НО3у7Soso1HgJPsnDn2pg==, base64), блок-лист хранится в перевёрнутом виде.

5.3. Этап кражи учётных данных (AiTM)

Прошедшие фильтры видят экран «Verifying your session... Validating email address...». Бэкенд одновременно выполняет реальные запросы аутентификации к IdP жертвы (Google Workspace или Microsoft 365), получая сессионные куки, валидные после прохождения MFA. Похищенные куки позволяют захватить сессию без обхода MFA.

5.4. Кластер инфраструктуры

Все семь доменов используют одинаковый DNS (DNSPod NS), один IP (198.23.210.61) и сертификаты Let's Encrypt одной даты выпуска — 17 апреля 2026 года. Единый PaaS-оператор с ротацией доменов.

Домен	Выдан cert	NS
stiofidri[.]company	2026-04-17	a/b/c.dnspod.com
giochogio[.]company	2026-04-17	a/b/c.dnspod.com
crepeawi[.]business	2026-04-17	a/b/c.dnspod.com
crivesha[.]company	2026-04-17	a/b/c.dnspod.com
driocriodio[.]app	2026-04-17	a/b/c.dnspod.com
beawoushoo[.]digital	2026-04-17	a/b/c.dnspod.com
shodiothai[.]enterprises	2026-04-17	a/b/c.dnspod.com

6. Индикаторы компрометации (IOC)

6.1. Вредоносная инфраструктура (блокировать)

Тип	Значение	Примечание
IP	198[.]23[.]210[.]61	RackNerd/ColoCrossing AS36352 — PaaS-фишинг VPS
Domain	stiofidri[.]company	Фишинг-кит — блокировать
Domain	giochogio[.]company	Кластер — блокировать
Domain	crepeawi[.]business	Кластер — блокировать
Domain	crivesha[.]company	Кластер — блокировать
Domain	driocriodio[.]app	Кластер — блокировать
Domain	beawoushoo[.]digital	Кластер — блокировать
Domain	shodiothai[.]enterprises	Кластер — блокировать
URL	hxxps://stiofidri[.]company/ u@xTBw1Q9qK4Qb0ZS9gxFUS /	Payload URL данной кампании
URL	hxxps://nam[.]jdcv[.]jms/ o9XDteis3W	Microsoft Customer Voice приманка (форма 404)

6.2. Fingerprints фишинг-кита

Индикатор	Значение
XOR-ключ (base64)	3HO3y7Soso1HgJPsnDn2pg==
API обнаружения sandbox	api[.]ipapi[.]is

Десоу-редирект	www[.]meituan[.]com
Паттерн URL-пути	/u@<случайный токен>/
Fingerprint бэкенда	Laravel (XSRF-TOKEN, laravel_session; samesite=none)
Title страницы (mid-flow)	«Verifying your session... Validating email address...»
Стиль CAPTCHA	Поддельный Gmail / Google identity check
Опечатка в title формы	«FILED» вместо «FILE» — повторяющаяся ошибка оператора

7. MITRE ATT&CK

ID	Техника	Наблюдение
T1583.001	Acquire Infrastructure: Domains	7 disposable-доменов за ~3 недели до атаки
T1583.004	Acquire Infrastructure: Server	RackNerd VPS 198.23.210.61 как PaaS-фронт
T1586.002	Compromise Accounts: Email Accounts	АТО М365-ящика (французская НКО, EU)
T1078.004	Valid Accounts: Cloud Accounts	Настоящий М365-аккаунт для отправки и создания Customer Voice форм
T1566.002	Phishing: Spearphishing Link	Целевое письмо с URL на финансовый ящик
T1566.003	Phishing: Spearphishing via Service	Microsoft Customer Voice (nam.dcv.ms) как доверенный промежуточный
T1656	Impersonation	Владелец ящика ложно представлен как CFO
T1036.005	Masquerading: Match Legitimate Name	nam.dcv.ms для обхода URL-фильтрации
T1027.013	Obfuscated Files: Encrypted/Encoded File	XOR-обфусцированный JS с base64-ключом
T1497.001	Virtualization/Sandbox Evasion: System Checks	Проверка через api.ipapi.is перед раскрытием payload
T1480	Execution Guardrails	CAPTCHA-шлюз перед второй стадией

T1539	Steal Web Session Cookie	AiTM-кит похищает сессионные куки для обхода MFA
T1056.003	Input Capture: Web Portal Capture	Поддельная страница входа Gmail/Google
T1114.002	Email Collection: Remote Email Collection	Реальный тред из ящика жертвы как контекст

8. Рекомендации

8.1. Для организации-отправителя

- Сбросить пароль и отозвать все refresh/access-токены скомпрометированного ящика через Entra ID.
- Проверить журналы входов Entra ID за апрель–май 2026: геоаномалии, успешные прохождения MFA, новые app-пароли или OAuth grants.
- Проверить правила ящика — возможны правила автопересылки или удаления уведомлений безопасности.
- Повысить политику DMARC с p=none до p=quarantine, затем p=reject.
- Сообщить о скомпрометированном аккаунте в Microsoft MSRC (msrc.microsoft.com/report/abuse); идентификаторы тенанта и пользователя доступны MSRC по запросу.

8.2. Отключение инфраструктуры

- Сообщить о 7 фишинговых доменах в Identity Digital: abuse@identity.digital
- Сообщить об IP 198.23.210.61 в RackNerd: abuse@racknerd.com
- Abuse-заявка в Cloudflare: cloudflare.com/abuse/form
- Сообщить в DNSPod (Tencent): abuse@dnspod.cn — отзыв DNS-делегирования.

8.3. Защита периметра

- Заблокировать 7 вредоносных доменов и IP 198.23.210.61 в DNS RPZ, web-proxy и email-шлюзе.
- НЕ блокировать nam.dcv.ms целиком — создать правило алерта: входящее с nam.dcv.ms/* + финансовые темы (ACH, Payment, Wire, EFT) от внешних отправителей → карантин.
- YARA/Sigma: XOR-fetch к api.ipapi.is с реверсированными строками провайдеров — высокоточная сигнатура семейства.
- Опечатка «FILED» вместо «FILE» — добавить как keyword в фишинговые правила.

8.4. Обучение пользователей

- Несоответствие роли в подписи (медицинский сотрудник как CFO) — красный флаг BEC.
- Microsoft Forms / Customer Voice — не канал для финансовых документов; любое такое перенаправление для АСН или платежа = подозрительно.
- Двуязычный тред: разные языки в верхнем сообщении и в цитате — признак thread hijacking.

TLP:CLEAR — Этот документ может распространяться без ограничений.